

Relatório de Auditoria de Segurança

NibasRockBar — pulseira NFC + BLE integrada ao Deli

Data: 10/09/2026 • Projeto: NibasRockBar • Classificação: uso interno

Escopo	Backend FastAPI (backend/app.py, backend/deli_adapter.py), firmware (firmware/main.c, firmware/nrf/main.c, gateway_esp32/gateway_esp32.ino), HTMLs estáticos, deploy (inexistente), git history, dependências.
Método	Revisão manual do código real (arquivo:linha), sem testes dinâmicos nem pentest; vereditos já verificados no código-fonte.

Nota metodológica — mapeamento das 5 categorias para a stack: Cat. 1 — autenticação, autorização e privacidade no backend (3 achados: A1, A2, M1); Cat. 2 — controle de acesso por papéis no frontend (0 — **N/A**: não há frontend com papéis; sem framework, HTMLs estáticos sem gates isAdmin/role); Cat. 3 — segurança de comunicação e protocolo BLE/MQTT (2: M4, B5); Cat. 4 — validação de entrada e tratamento de erros (3: B1, B2, B3); Cat. 5 — exposição de superfície, configuração, segredos e dependências (5: M2, M3, B4, I1, I2). Nenhum achado crítico (0).

13 achados • 2 altos • 4 médios • 5 baixos • 2 informativos • 9 pontos fortes

1 Resumo executivo

A auditoria encontrou **13 achados** e nenhum de severidade crítica. Os dois achados altos (A1, A2) concentram o risco real: as rotas de escrita operam o sistema fiscal externo (Deli) sem autenticação, de modo que qualquer host na rede cria ou encerra vendas. Quatro achados médios ampliam a superfície (localização/comandas legíveis sem auth e MQTT sem auth/TLS). Cinco achados baixos e dois informativos pedem endurecimento de validação, configuração e dependências. Em contrapartida, há **9 pontos fortes verificados** — SQL 100% parametrizado, segredos só via ambiente e parser BLE defensivo — que devem ser preservados. Deploy é inexistente (sem TLS reverso, sem segredo de produção avaliável).

Severidade	Qtd
Crítica	0
Alta	2
Média	4
Baixa	5
Informativa	2
Total de achados	13
Pontos fortes	9

Achados por severidade (+ pontos fortes)

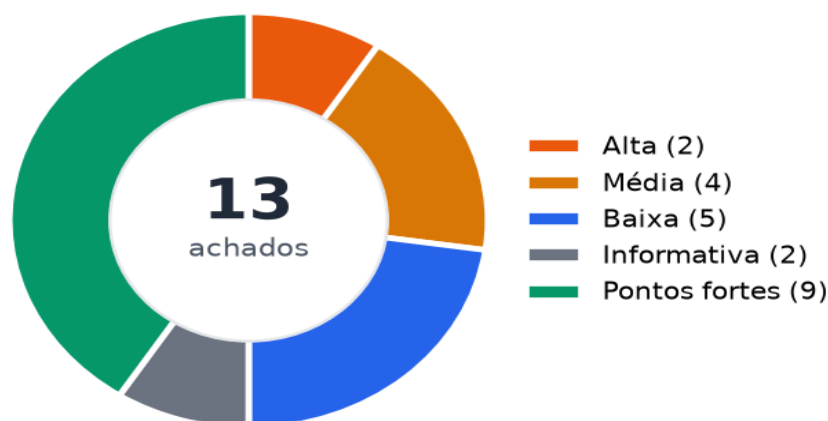


Figura 1 — distribuição por severidade. Crítica: 0 (sem fatia). Informativa em cinza neutro; pontos fortes em verde.

Achados por categoria de auditoria

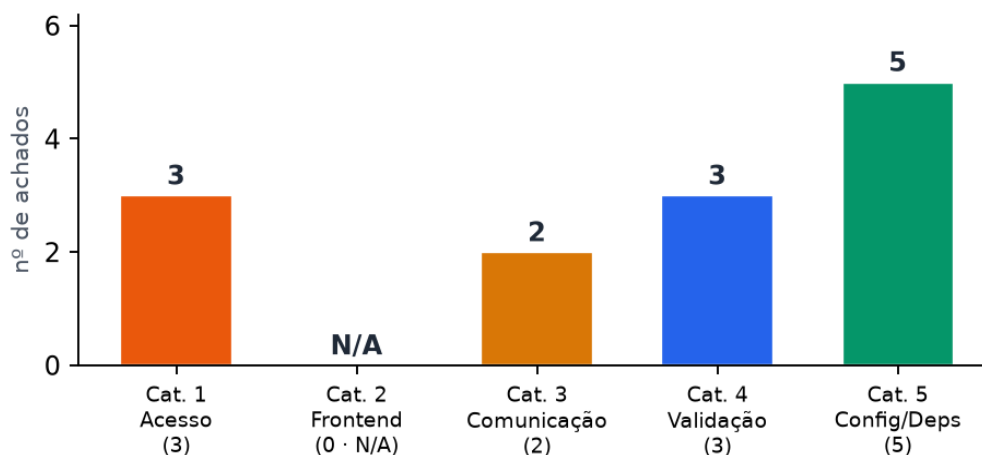


Figura 2 — achados por categoria. Cat. 2 = 0 (N/A: sem frontend com papéis).

2 Pontos fortes vs. pontos fracos

Pontos fortes (evidência verificada)

- F1 — SQL 100% parametrizado (app.py:250, 267-274, 285, 292-293, 309, 317-318, 327 — sem concatenação).
- F2 — Segredos Deli somente via env com fail-fast (deli_adapter.py:54-59) e nunca hardcoded.
- F3 — Histórico git limpo de segredos reais; .env ignorado.
- F4 — Parser BLE do gateway valida length/company_id/casts (ino:93, 99, 102-103, 107-108).
- F5 — SAADC com clamp (main.c).
- F6 — snprintf com sizeof (ino:142-143).
- F7 — MQTT com try/except (app.py:185-197).
- F8 — HTMLs sem innerHTML/fetch.
- F9 — Sem Jinja/smtplib no backend.

Categoria 2 = N/A: não há frontend com papéis — sem framework; HTMLs estáticos sem gates isAdmin/role; portanto nada a auditar nessa categoria.

Pontos fracos (síntese)

- **Escrita sem auth (A1, A2 — alta):** checkin abre comanda fiscal e checkout libera pulseira sem verificar o chamador.
- **Leitura sem auth (M1, M2, M3 — média):** localização em tempo real e dumps de pulseiras/tags acessíveis a qualquer host.
- **Canal sem proteção (M4 — média):** MQTT sem auth/TLS permite telemetria falsa e espionagem.
- **Validação e erros (B1, B2, B3, B5 — baixa):** inputs sem formato, sale_id sem regex, erro upstream ecoado e proto BLE ignorado.
- **Higiene (B4, I1, I2 — baixa/informativa):** .gitignore incompleto, placeholders WiFi e deps sem pin.

3 Tabela de achados

Treze achados verificados no código real. Severidade indicada por chip colorido; “Cat.” remete às categorias da nota metodológica (capa).

ID	Sev.	Cat.	Arquivo:linha	Descrição
A1	ALTA	1	backend/app.py:246	POST /pulseiras/checkin abre comanda no Deli (sistema fiscal externo) sem autenticação/autorização — qualquer host na rede cria vendas. Trecho: def checkin_pulseira(req: CheckinRequest) + DeliClient.abrir_comanda().
A2	ALTA	1	backend/app.py:278	POST /pulseiras/checkout libera qualquer pulseira (nfc_uid no body, sem verificar chamador) — qualquer host encerra comandas. Trecho: def checkout_pulseira(req: CheckoutRequest) + UPDATE pulseiras SET status='livre'.
M1	MÉDIA	1	backend/app.py:217	GET /localizacao/{mac} expõe localização em tempo real de qualquer cliente sem auth (privacidade). Trecho: def get_localizacao(mac: str) lê_tag_states[mac].
M2	MÉDIA	5	backend/app.py:323	GET /pulseiras retorna dump completo (nfc_uid, ble_mac, status, comanda_id) sem filtro/paginação/auth.
M3	MÉDIA	5	backend/app.py:335	GET /localizacoes expõe todas as tags online sem auth.
M4	MÉDIA	3	gateway_esp32/gateway_esp32.ino:75 + backend/app.py:41-43	MQTT sem auth/TLS (broker 192.168.0.10:1883, connect sem user/pass) — qualquer host publica telemetria falsa ou assina dados.
B1	BAIXA	4	backend/app.py:233-240	CheckinRequest/CheckoutRequest sem pattern/min_length (nfc_uid/ble_mac/table_id arbitrários) — vão para SQLite e API Deli sem validação de formato.
B2	BAIXA	4	backend/deli_adapter.py:12-133	comanda_id do banco vai direto para GET /sales/{sale_id} sem validar ^[A-Za-z0-9_-]+\$.
B3	BAIXA	4	backend/deli_adapter.py:75, 92 + backend/app.py:263	Corpo de erro do Deli (resp.text) refletido no detail do 502 — info-leak menor (JSON, não HTML).
B4	BAIXA	5	.gitignore:1-8 + backend/app.py:44	.gitignore não cobre *.db/_build — smartbadge.db (dados de clientes) e .bin/.hex do nRF podem ser commitados por acidente.
B5	BAIXA	3	gateway_esp32/gateway_esp32.ino:90-108	proto_version do pacote BLE ignorado — pacote futuro/incompatível passa (battery/seq sem range-check).
I1	INFORMATIVA	5	gateway_esp32/gateway_esp32.ino:24-28	Placeholders WiFi commitados de propósito (PUB_WIFI/SENHA_AQUI) com TODO — risco futuro se credencial real for commitada.
I2	INFORMATIVA	5	backend/requirements.txt:1-4 + gateway.ino:20-21 + modelo_3d_prototipo.html:7	Deps sem lock/pin (paho-mqtt 1.6 ramo antigo, ArduinoJson/PubSubClient sem versão, three.js r128 CDN 2021).

4 Recomendações

Ordenadas por prioridade (P1 = maior risco/urgência).

P1 — Exigir API key/Bearer no backend + checar chamador nas rotas de escrita

Cobre A1, A2. Autenticar todas as rotas de escrita (checkin/checkout) e validar que o chamador tem permissão sobre a pulseira/comanda informada.

P2 — Habilitar auth + TLS no Mosquitto e credenciais por gateway

Cobre M4. Configurar username/senha por gateway, TLS no broker e ACLs por tópico; remover o connect anônimo contra 192.168.0.10:1883.

P3 — Rate-limit/paginação e auth nas rotas de leitura

Cobre M1, M2, M3. Exigir autenticação nas rotas de leitura, adicionar paginação/filtro e rate-limit para conter enumeração de clientes e tags.

P4 — Validar formatos (UUID/MAC/table/sale_id) com pydantic pattern

Cobre B1, B2 e gateway proto (B5). Adicionar pattern/min_length nos schemas e validar sale_id contra `^[A-Za-z0-9_-]+`; checar proto_version e ranges (battery/seq) no gateway.

P5 — .gitignore += *.db *.sqlite firmware/**/_build *.bin *.hex

Cobre B4. Impedir commit acidental de smartbadge.db (dados de clientes) e binários do nRF.

P6 — Parar de ecoar resp.text do Deli; logar interno

Cobre B3. Retornar mensagem genérica no 502 e registrar o corpo upstream apenas em log interno.

P7 — Pinar deps (pip freeze/SBOM, paho-mqtt 2.x, ArduinoJson v7) + trocar three.js r128

Cobre I2. Travar versões, gerar SBOM, migrar paho-mqtt para o ramo 2.x e substituir o three.js r128 (CDN, 2021) por versão atual.

P8 — Provisioning NVS + nunca commitar WiFi real

Cobre I1. Manter placeholders fora do repo ou usar provisioning em NVS; bloquear credenciais reais com pre-commit/CI.

5 Issues para o GitHub

Sete issues prontas para abertura, com texto Markdown completo entre os delimitadores `---` `ISSUE n` `---` e `---` `FIM ISSUE n` `---`.

`---` `ISSUE 1` `---`

[Segurança] Rotas de escrita sem autenticação — checkin/checkout

Labels: security, alta

```
## Problema
`POST /pulseiras/checkin` e `POST /pulseiras/checkout` não exigem autenticação nem
autorização: qualquer host com acesso à rede do backend abre comandas no Deli
(sistema fiscal externo) e libera pulseiras.

## Evidência
- `backend/app.py:246` — `def checkin_pulseira(req: CheckinRequest)` +
`DeliClient.abrir_comanda()`
- `backend/app.py:278` — `def checkout_pulseira(req: CheckoutRequest)` +
`UPDATE pulseiras SET status='livre'` (nfc_uid vem do body, chamador não verificado)

## Impacto
Criação de vendas fraudulentas no sistema fiscal, encerramento indevido de comandas,
divergência de caixa e risco fiscal/contábil.

## Correção
- Exigir API key/Bearer em todas as rotas de escrita (P1).
- Verificar que o chamador tem permissão sobre a pulseira/comanda (check de chamador).
- Considerar rate-limit e trilha de auditoria (quem/quando).

## Aceite
- [ ] Requisição sem credencial retorna 401/403 em `/pulseiras/checkin` e `/pulseiras/checkout`.
```

- [] Credencial válida sem permissão sobre a pulseira é negada.
- [] Teste automatizado cobre os dois casos.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

[Segurança] Leitura de localização/comandas sem auth

Labels: security, média

Problema

Rotas de leitura expõem localização em tempo real e dump de comandas sem autenticação, filtro ou paginação.

Evidência

- `backend/app.py:217` — `def get\_localizacao(mac: str)` lê `\_tag\_states[mac]`
- `backend/app.py:323` — `GET /pulseiras` retorna `nfc\_uid, ble\_mac, status, comanda\_id`
- `backend/app.py:335` — `GET /localizacoes` expõe todas as tags online

Impacto

Rastreamento de clientes (privacidade), enumeração de comandas ativas e vazamento de identificadores (nfc_uid/ble_mac).

Correção

- Exigir auth nas rotas de leitura (P3).
- Adicionar paginação/filtro e rate-limit contra enumeração.
- Avaliar minimização: retornar só o necessário por chamador.

Aceite

- [] Rotas retornam 401/403 sem credencial.
- [] Listagens paginadas com limite padrão.
- [] Rate-limit ativo e testado.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

[Segurança] MQTT sem auth/TLS permite telemetria falsa

Labels: security, média

Problema

O gateway conecta ao broker sem usuário/senha e sem TLS; qualquer host pode publicar telemetria falsa ou assinar os dados de localização.

Evidência

- `gateway\_esp32/gateway\_esp32.ino:75` — connect sem user/pass
- `backend/app.py:41-43` — cliente MQTT sem auth/TLS
- Broker `192.168.0.10:1883` (porta plaintext)

Impacto

Localização forjada (garçom vai à mesa errada), replay de pacotes e espionagem do tráfego de telemetria na rede do pub.

Correção

- Habilitar auth + TLS no Mosquitto, credencial por gateway (P2).
- ACLs por tópico; negar anonymous.
- Provisionar senhas fora do código (NVS/secret).

Aceite

- [] Broker recusa conexão anônima e plaintext.
- [] Gateway e backend conectam via TLS com credenciais.
- [] ACL impede gateway de assinar/publicar fora do seu namespace.

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

[Segurança] Validar formatos de input

Labels: security, baixa

Problema

Identificadores entram sem validação de formato e fluem para SQLite, API Deli e parser BLE.

Evidência

```
- `backend/app.py:233-240` — `CheckinRequest`/`CheckoutRequest` sem `pattern`/`min_length`
(`nfc_uid`/`ble_mac`/`table_id` arbitrários)
- `backend/deli_adapter.py:124-133` — `comanda_id` vai direto a `GET /sales/{sale_id}`
sem validar `[A-Za-z0-9_-]+$`
- `gateway_esp32/gateway_esp32.ino:90-108` — `proto_version` ignorado; `battery`/`seq`
sem range-check

## Impacto
Dados malformados chegam ao sistema fiscal, erro de localização por pacote incompatível e
superfície para injection/path-confusion no `sale_id`.

## Correção
- Schemas pydantic com `pattern` (UUID/MAC/table/sale_id) — P4.
- Rejeitar `proto_version` desconhecido e validar ranges no gateway.

## Aceite
- [ ] Inputs fora do formato retornam 422.
- [ ] Pacote BLE com versão desconhecida é descartado (log).
- [ ] Testes de formato para cada campo.
```

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

[Segurança] .gitignore não cobre banco e binários

Labels: security, baixa

```
## Problema
O `.gitignore` não cobre `*.db`/`*_build`, permitindo commit acidental do banco de clientes
e de binários do firmware.

## Evidência
- `.gitignore:1-8` — sem regra para `*.db`, `*.sqlite`, `*_build`, `*.bin`, `*.hex`
- `backend/app.py:44` — `smartbadge.db` (dados de clientes)

## Impacto
Vazamento de dados de clientes no histórico git (difícil de expurgar) e poluição do repo
com artefatos de build.

## Correção
- `.gitignore += *.db *.sqlite firmware/**/*_build *.bin *.hex` (P5).
- Auditar histórico por artefatos já commitados.

## Aceite
- [ ] `git status` limpo após build + execução local.
- [ ] CI falha se artefato for adicionado.
```

--- FIM ISSUE 5 ---

--- ISSUE 6 ---

[Segurança] Erro upstream refletido no 502

Labels: security, baixa

```
## Problema
O corpo de erro da API Deli é refletido no `detail` do 502, expondo conteúdo upstream
ao chamador.

## Evidência
- `backend/deli_adapter.py:75,92` — usa `resp.text` no erro
- `backend/app.py:263` — repassa ao `detail` do 502

## Impacto
Info-leak menor (JSON, não HTML): detalhes internos do integrador/fiscal podem vaziar para
qualquer chamador da API.

## Correção
- Retornar mensagem genérica no 502 e logar o corpo internamente (P6).

## Aceite
- [ ] 502 não contém `resp.text` do upstream.
- [ ] Corpo upstream aparece no log interno com correlation-id.
```

--- FIM ISSUE 6 ---

--- ISSUE 7 ---

[Segurança] Higiene de dependências e placeholders

Labels: security, informativa

Problema

Dependências sem lock/pin e placeholders de WiFi no código criam risco de supply-chain e de commit acidental de credencial.

Evidência

- `backend/requirements.txt:1-4` – sem lock (`paho-mqtt 1.6`, ramo antigo)
- `gateway\_esp32.ino:20-21` – `ArduinoJson`/`PubSubClient` sem versão
- `modelo\_3d\_prototipo.html:7` – `three.js r128` via CDN (2021)
- `gateway\_esp32.ino:24-28` – placeholders `PUB\_WIFI`/`SENHA\_AQUI` com TODO

Impacto

Builds não reproduzíveis, vulnerabilidades conhecidas em lib antiga e risco futuro de credencial real commitada.

Correção

- `pip freeze`/SBOM, paho-mqtt 2.x, ArduinoJson v7, trocar three.js r128 (P7).
- Provisioning via NVS; nunca commitar WiFi real; pre-commit/CI (P8).

Aceite

- [] Lockfile/SBOM gerado e CI verifica.
- [] `grep` por credencial real no CI.
- [] three.js atualizado ou removido do CDN antigo.

--- FIM ISSUE 7 ---